

MEHER SUDHAKAR ABBIREDDI

(240) 340-0064 | msabbi2022@gmail.com | linkedin.com/in/meher-sudhakar | github.com/Mehersudhakar

PROFESSIONAL SUMMARY

Cybersecurity professional with 3+ years in penetration testing, offensive security, vulnerability exploitation, and AI/LLM red teaming. Hands-on with attack-chain construction, authentication and authorization bypass, privilege escalation, lateral movement, post-exploitation, source-level review for exploitation primitives, and adversarial testing of production AI systems. Surfaced 30+ confirmed vulnerabilities including a novel Denial-of-Wallet attack class on a production RAG pipeline, a high-severity JWT lifecycle flaw on an OAuth-based multi-tenant SaaS platform, and 25+ critical findings at DXC contributing to a 35% reduction in production incidents. Certified eJPT, CompTIA Security+, and CEH, currently pursuing OSCP.

PROFESSIONAL EXPERIENCE

Cybertrust America | Cybersecurity Engineer

Jun 2025 – Present

- Led an authenticated web application penetration test on an **OAuth**-based multi-tenant SaaS platform, surfacing a high-severity JWT lifecycle flaw allowing sessions to persist beyond logout, validated with a working PoC and remediated pre-attestation.
- Designed and executed multi-phase penetration tests against a production RAG-based AI application, uncovering 4+ high-severity findings including a novel **Denial-of-Wallet** attack class, LLM prompt injection, and agentic access-control bypass using **Burp Suite** and custom Python exploits.
- Scoped a **SOC 2**-aligned point-in-time pentest across application, authentication, and browser security controls, calibrating finding severity to demonstrated attacker capability and surfacing client-side information disclosure via frontend asset review.
- Constructed multi-step attack chains from prompt injection through data exfiltration and privilege escalation, validating end-to-end exploitability via controlled PoCs against LLM orchestration, retrieval pipelines, and identity integration points.
- Conducted source-level review of LLM orchestration and agentic integration code to identify prompt-injection entry points, hardcoded credentials, and unsafe user-input handoffs feeding downstream attack chains.
- Ran AI red-team exercises against deployed LLM systems, designing adversarial test suites that proved guardrail-bypass paths and mapped them to OWASP LLM Top 10 categories with hardening recommendations adopted pre-deployment.
- Drafted client-facing penetration-test reports scoped to **CVSS v3** and **OWASP Top 10** with technical PoCs and step-by-step remediation guidance, partnering with engineering through fix verification and retest cycles.

University of Maryland, College Park | Security Analyst

Aug 2024 – May 2025

- Executed authenticated and unauthenticated penetration tests against production business web applications, exploiting injection, broken authentication, and access-control flaws end-to-end with working PoC payloads delivered to application owners.
- Ran offensive scenarios against enterprise **Linux** and **Windows** infrastructure, chaining service misconfigurations and credential exposure into multi-host pivot paths documented for infrastructure stakeholders.
- Discovered cloud workload exposure across IAM misconfiguration, public-bucket exposure, and over-scoped role assumptions in production cloud environments, routing fix priorities to application owners by exploitability.
- Built Python tooling to automate enumeration and exploit-validation across recurring engagements, cutting per-engagement setup time and standardizing output flowing into client-facing reports.

DXC Technology | Security Engineer

Jun 2022 – Aug 2023

- Performed adversarial threat modeling and **attack-surface analysis** across distributed product architectures, mapping exploitation paths and validating attacker-reachable flaws pre-production for engineering teams.
- Discovered 25+ critical vulnerabilities across web, mobile, API, and desktop clients including injection flaws (XSS, CSRF, SQLi) and authentication bypass in **OAuth** and JWT-based identity flows, contributing to a 35% reduction in production incidents.
- Executed social engineering campaigns including phishing simulations and pretext-based payload delivery to validate user-awareness controls and email-security filters during red-team engagements.
- Performed vulnerability scanning and threat-emulation drills on 100+ **Linux** and **Windows** systems using **Nessus** and Nmap, prioritizing remediation by CVSS score, asset criticality, and exploitability.
- Developed Python-based exploit-validation scripts and lightweight C tooling to accelerate attack-surface enumeration and deliver actionable PoCs during ongoing engagements.

Verzeo | Web Application Penetration Tester

Oct 2021 – Jun 2022

- Exploited **SQL Injection**, XSS, CSRF, and IDOR end-to-end on production web targets with working PoC payloads, delivering reproduction steps that drove risk-prioritized remediation across in-scope modules.

- Performed manual source code review during pentest engagements to surface input-validation, authentication, and authorization flaws missed by dynamic scanners, paired with PoC exploit payloads.
- Automated reconnaissance and attack-surface mapping using Nmap and custom Python tooling, reducing manual enumeration effort by 30% and expanding coverage across system components and backend services.

PROJECTS

Pentigo - Autonomous AI Penetration Testing Platform

- Built a multi-agent orchestration system that autonomously chains reconnaissance, scanning, enumeration, exploitation, and post-exploitation phases, each phase gated on prior findings to mirror how a human pentester scopes follow-up.
- Integrated standard pentest tooling (Nmap, Metasploit, sqlmap, ffuf) through a unified tool-calling layer that passes findings between phases and triggers context-aware follow-up probes against intentionally vulnerable VMs and CTF targets.

AI Red-Team Testing - Code Generation Systems

- Built an offensive testing harness against AI code-generation systems, classifying hundreds of working jailbreak variants into an attack taxonomy and demonstrating systematic guardrail-bypass paths aligned to **OWASP LLM Top 10**.
- Chained successful bypasses end-to-end across direct prompt injection, indirect context injection, and multi-turn escalation, delivering each as a reproducible attack scenario with paired mitigation paths for engineering teams.

ReconX - Modular Reconnaissance Automation Framework

- Built a Python framework automating subdomain enumeration, port scanning, service fingerprinting, and HTTP probing across attack-surface engagements, normalizing heterogeneous tool output into a structured schema feeding downstream analysis.
- Implemented configurable scan profiles (passive, active, aggressive) and a plugin interface for new modules, reducing manual recon setup time across multi-service engagements while keeping per-engagement scoping flexible.

SKILLS

Penetration Testing & Offensive Security: Manual web application and API exploitation, network penetration testing, authentication and authorization bypass (OAuth 2.0, OIDC, JWT, SAML), exploit chains, exploit development, exploit validation, privilege escalation, lateral movement, attack-surface enumeration, reconnaissance, post-exploitation, social engineering, phishing simulation, bug bounty / responsible disclosure

AI Red Team & LLM Security: Prompt injection (direct and indirect), Denial-of-Wallet attack design, multi-step LLM exploit chaining, jailbreak taxonomy, guardrail-bypass testing, RAG pipeline attack surface, agentic access-control bypass, AI red-team adversarial testing, **OWASP LLM Top 10**

Application & Code-Level Security: Manual source code review, **STRIDE** threat modeling, **SAST/DAST/SCA** integration, CI/CD security gates, attack-surface analysis, vulnerability triage, **OWASP Top 10**, OWASP API Security Top 10

Programming & Scripting: Python, JavaScript, PowerShell, Bash, Unix Shell, C, C++, SQL, exploit scripting, automation tooling, JSON schema design

Security Tools: Burp Suite, OWASP ZAP, Nmap, Nessus, Metasploit, sqlmap, ffuf, gobuster, Hydra, Hashcat, Wireshark, Postman, Git/GitHub, SonarQube, Veracode, Checkmarx, Snyk

Cloud, Infrastructure & Standards: AWS (IAM, S3, EC2, Lambda assessment), Docker, Linux (Kali, Ubuntu), Windows Server, macOS; Jenkins, GitHub Actions, GitLab CI; **MITRE ATT&CK**, NIST CSF, NIST 800-53, CIS Controls, **CVSS v3**, ISO 27001, SOC 2, PCI DSS, HIPAA, PTES

CERTIFICATIONS

Offensive Security Certified Professional (OSCP) – Offensive Security (Pursuing) | Junior Penetration Tester (eJPT) – INE | CompTIA Security+ – CompTIA | Certified Ethical Hacker (CEH) – EC-Council

EDUCATION

University of Maryland, College Park | Master of Engineering, Cybersecurity

Aug 2023 – May 2025

Coursework: Hacking of C Programs & Unix Binaries, Cloud Security, Reverse Engineering, Digital Forensics, Cryptography, Operating Systems, Information Security, Network Security, Cloud Computing.